Executive Summary

Enterprise Cloud Risk Management Assessment

Project Overview

This project applied the National Institute of Standards and Technology (NIST) Risk Management Framework (RMF) to a simulated government information system operated by the fictional State Institute of Science and Technology (SIST). The assessment focused on the AWS-hosted SIST Web Infrastructure System (SWI), supporting Human Resources (HR), Financial and Contract Information Network (FCIN), and Graduate Management Admission Testing (GMAT) applications.

The objective was to evaluate security requirements, identify potential risks, and develop governance and compliance documentation to support secure cloud operations. Using the high-water-mark approach, the system was categorized as **High impact for confidentiality, integrity, and availability**, based on the information types and assumptions documented in the security categorization assessment.

Scope

The assessment focused on the proposed AWS web infrastructure, including web, application, and database servers, identity and access management, audit logging, and continuous monitoring capabilities. The SIST Data Center, Azure environment, SISTNet WAN, and Zscaler services were considered external interconnected systems or service providers within the initial assessment.

Key activities included:

- Security categorization and high-water-mark analysis
- Identification of potential security risks
- System Security Plan (SSP) development
- AU-2 Audit Events control assessment planning
- AWS audit logging and monitoring strategy development
- Continuous monitoring and infrastructure migration risk analysis

Technologies and Frameworks

- NIST Risk Management Framework (RMF)
- NIST SP 800-53 and SP 800-53A
- NIST SP 800-60
- NIST SP 800-137
- AWS Identity and Access Management (IAM)
- AWS CloudTrail

- Amazon CloudWatch Logs
- Amazon S3
- AWS Config

Key Outcomes

The project established a proposed security governance approach for the High-impact SIST Web Infrastructure System. It documented security categorization decisions, defined the initial system boundary, outlined audit-event assessment procedures, and developed a continuous monitoring strategy.

Major deliverables included:

- Security Categorization Assessment
- System Security Plan (SSP)
- AU-2 Audit Events Control Assessment Plan
- Information Security Continuous Monitoring (ISCM) Strategy

The assessment also examined a hypothetical infrastructure migration involving the decommissioning of Azure and the movement of services to AWS and the SIST Data Center. Potential risks included security misconfigurations, loss of inherited controls, expanded attack surfaces, unauthorized access, and data migration failures.

Recommendations included implementing automated configuration compliance monitoring, strengthening identity and access management, centralizing security logging, and updating security documentation following significant infrastructure changes.

Lessons Learned

This project strengthened my understanding of cloud governance, risk management, security categorization, control assessment planning, and the NIST Risk Management Framework. It demonstrated the importance of aligning technical security controls with organizational requirements, documenting system boundaries, and evaluating how infrastructure changes affect security risks.

The project was completed as an academic simulation. The proposed AWS architecture, security controls, and assessment procedures were documented for planning and analysis purposes and do not represent a verified production deployment or completed technical control testing.